Compliance Annotation

Framework: GDPR | **Compliance Level:** Non-Compliant / High Risk

NovaSphere Analytics GmbH

Finding 1: [COMPLIANT] Identification of Controller and DPO (Art. 13(1)(a-b)) The policy explicitly identifies NovaSphere Analytics GmbH as the controller, provides a physical address in Berlin, and names a specific Data Protection Officer (Dr. Klaus Weber) with a dedicated contact email. **References:** GDPR Art. 13(1)(a-b), Art. 37.

Finding 2: [VIOLATION] Invalid Bundled Consent for Marketing (Art. 7(4)) NovaSphere bundles the acceptance of the Privacy Policy and account creation with consent for marketing, targeted advertising, and cross-device tracking. This violates the requirement that consent must be "freely given" and granular; processing for marketing cannot be a condition for a service contract. **References:** GDPR Art. 7(2), Art. 7(4), Recital 43.

Finding 3: [VIOLATION] Unlawful Use of Legitimate Interests for ML Training (Art. 6(1)(f)) The processing of session recordings and behavioral signals to train proprietary machine learning models is claimed under "legitimate interests". This high-impact processing, particularly session recordings which capture granular user interactions, likely fails the balancing test and necessitates a Data Protection Impact Assessment (DPIA). **References:** GDPR Art. 6(1)(f), Art. 35.

Finding 4: [VIOLATION] Automated Decision-Making Affecting Access & Pricing (Art. 22) NovaSphere uses automated engagement scoring and churn-risk profiling to influence pricing tiers and feature access. This constitutes automated decision-making with "similarly significant effects". The policy incorrectly relies on legitimate interests instead of obtaining explicit consent or fulfilling the safeguard requirements of Art. 22(3), such as the right to human intervention. **References:** GDPR Art. 22, Recital 71.

Finding 5: [VIOLATION] Excessive Verification Requirements for User Rights (Art. 12(2)) The requirement for users to upload a government-issued photo ID and complete a video verification call to exercise basic data rights (access, erasure, etc.) is a disproportionate barrier. Controllers may only request additional information to confirm identity if they have "reasonable doubts," and such "verification-as-a-barrier" constitutes a dark pattern. **References:** GDPR Art. 12(2), EDPB Guidelines 03/2022 on Dark Patterns.

Finding 6: [VIOLATION] Dark Pattern in Consent Withdrawal (Art. 7(3)) Withdrawing marketing consent requires navigating a complex six-level menu structure. This violates the "equivalence principle," which mandates that withdrawing consent must be as easy as giving it. **References:** GDPR Art. 7(3), EDPB Guidelines 03/2022 on Dark Patterns.

Finding 7: [VIOLATION] Invalid "Consent by Browsing" for Cookies (Art. 4(11)) The policy states that continuing to browse after dismissing a cookie banner constitutes consent for all cookie categories. This is legally invalid as consent requires a clear affirmative action; passive browsing or the mere dismissal of a notification does not meet the GDPR standard. **References:** GDPR Art. 4(11), CJEU Case C-673/17 (Planet49).

Finding 8: [VIOLATION] Non-Compliant Storage Limitation (Art. 5(1)(e)) The policy states that "aggregated analytics data" derived from usage may be retained "indefinitely". Unless this data is truly anonymized to the point of irreversibility, indefinite retention violates the principle of storage limitation, which requires data to be kept only as long as necessary for the purpose of processing. **References:** GDPR Art. 5(1)(e), Art. 13(2)(a).

Finding 9: [VIOLATION] Failure to Provide Art. 14 Information for Indirect Collection While the policy acknowledges receiving data from "business intelligence data brokers" and "integrated sources" , it does not specify how it fulfills the obligation to notify these data subjects within one month, as required when data is not obtained directly from the individual. **References:** GDPR Art. 14.

Finding 10: [VIOLATION] Lack of Specificity in International Transfer Safeguards The policy lists transfers to the US and "other countries" but fails to mention supplementary measures or Transfer Impact Assessments (TIAs). Reliance on Standard Contractual Clauses (SCCs) alone, without assessing the legal environment of the recipient country (e.g., Delaware, USA for the parent company), is insufficient. **References:** GDPR Art. 44-49, CJEU Case C-311/18 (Schrems II).

Finding 11: [VIOLATION] Unlawful Policy Change Acceptance (Art. 12) The claim that "continued use of the platform" constitutes acceptance of revised policy terms is invalid. For processing activities based on consent, silence or continued activity cannot replace the requirement for a clear, affirmative opt-in to new terms. **References:** GDPR Art. 7, Art. 12, Recital 42.